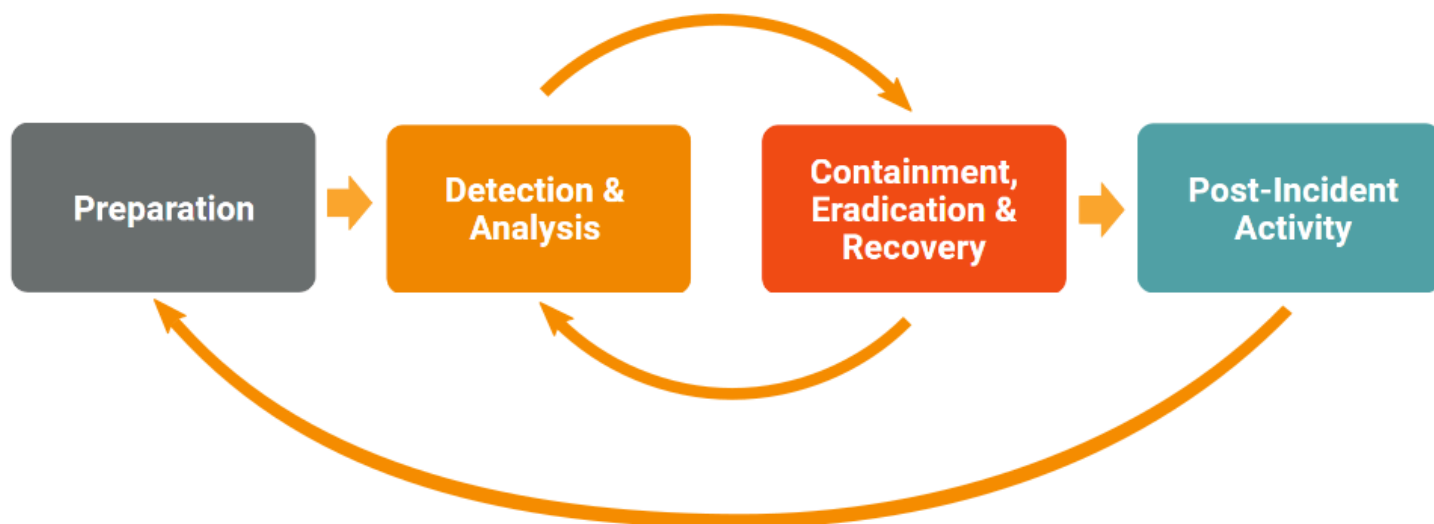


Network Scan Incident Response Playbook

The Lumu Network Scan Incident Response Playbook is based on the Computer Security Incident Handling Guide by the National Institute of Standards and Technology (NIST). According to NIST special publication [800-61](#), the incident response life cycle has four main phases, as described below.



This document contains guidelines for network scan incident response using Lumu. Consider this playbook as a guideline to improve the effectiveness of the incident response and adapt it according to your specific requirements.

What is a Network Scan?

A network scan occurs when intruders collect information on the services and resources on a target network. Network scanning isn't inherently hostile, but adversaries often use it to conduct reconnaissance before trying to breach a network.

There are two types of attacks that we should define before going forward:

- **Network scanning:** involves detecting all active hosts on a network and mapping them to their IP addresses.
- **Port scanning:** refers to the process of sending packets to specific ports on a host and analyzing the responses to learn details about its running services or the location of potential vulnerabilities.

The adversary will try to find open ports on the target system. A few scanning methods used by network attackers to gather information on your network are:

- **Vanilla scan/SYNC scan:** TCP SYN packets are sent to the ports of each address in an attempt to connect to all ports. Port numbers 0 – 65,535 are utilized.
- **Strobe scan:** the attacker attempts to connect to a specific range of ports, which are typically open on Windows-based hosts or UNIX/Linux-based hosts.
- **Sweep scan:** Scans a large set of IP addresses in an attempt to detect a system that has an open port.
- **Passive scan:** occurs when network traffic entering or leaving the network is captured and the traffic is then analyzed to determine which ports are open on the hosts within the network.
- **User Datagram Protocol (UDP) scan:** empty UDP packets are sent to different ports of a set of addresses to determine how the operating system responds. Closed UDP ports respond with the 'Port Unreachable' message when any empty UDP packets are received. Other operating systems respond with the Internet Control Message Protocol (ICMP) error packet.
- **FTP bounce scan:** this scan is initiated from an intermediary File Transfer Protocol (FTP) server in an attempt to hide the location of the attacker.
- **FIN scan:** TCP FIN packets that specify that the sender wants to close a TCP session are sent to each port for a range of IP addresses.

Preparation

This is the initial phase where organizations plan measures to respond effectively to incidents when they are discovered.

How Lumu Helps

Unlocking the value of your own network metadata to provide enhanced compromise visibility.

Recommended Actions

- Make sure that all the network metadata is ingested in the Lumu platform. [Learn more in our deployment guide](#).
- Make good use of the [Labels feature](#) offered by Lumu. Having appropriate names for your endpoints and LVAs can be very helpful when categorizing your traffic and identifying incidents.
- If there are any remote users in your network, make sure they are covered by your Continuous Compromise Assessment strategy. To learn more about how to ensure this, refer to our [article about VPN and SDP configuration](#).
- Make sure to configure your switch/router correctly to capture network metadata. To learn more about how to carry out this configuration, refer to the documentation of your device's manufacturer. Alternatively, software such as PacketBeat or Ntop set up on one of the switch's mirror ports can be used to capture this type of metadata.
- Make sure that you have deployed Lumu Virtual Appliances (VA) and that they are capturing NetFlow metadata. To achieve this, your network's devices must forward NetFlow logs to the Lumu VA, or alternatively must have PacketBeat configured as an external collector.. To learn more about this collector, refer to our article about [PacketBeat](#).

Detection & Analysis

Organizations should work to detect and validate incidents as quickly as they can. Early detection helps organizations to control the number of infected systems and makes the next phase easier.

How Lumu Helps

Providing the ability to illuminate the blind spots in your network by implementing the concept of Continuous Compromise Assessment.

Recommended Actions

- Identify the devices performing the network scan activity by using the incidents tab in the Lumu Portal. You can find this information at a glance in the [Activity section](#) of the Lumu Portal.
- Identify the network segments that triggered the activity in order to assess the priority and risk of this incident, and to determine the level of activity across your network.
- Identify associated IOCs detected on the same endpoints by looking at the [distribution tab](#) in the Lumu Portal.
- Check if any of the related IOCs has Network Service Scanning capabilities by looking at the [MITRE ATT&CK Matrix](#) in the Context tab of the Lumu portal. If you have identified this capability in the detected threat, this triggers the probability that the detected network scanning activity is associated with seen IOCs on that device and network segment.
- Validate that the activity is not part of a legitimate penetration test or red team activity.

Containment, Eradication, & Recovery

This phase has two key goals, stopping the spread of the threat and preventing more damage inside the network. Organizations should have strategies and procedures according to the level of risk of the detected compromise.

How Lumu Helps

Confirmed compromise intelligence about the compromised device helps security analysts to understand where and how to contain and eradicate the compromise.

Recommended Actions

- Identify and isolate endpoints where activity was detected. When threat actors start to perform network scans, the usual reason is network discovery. They already have initial access to your network and are trying to identify valuable or vulnerable assets in order to achieve lateral movements.
- [Lumu Defender](#), the most advanced Lumu subscription tier, features [response integrations](#) that allow Lumu to obtain even more precise intelligence and to promptly respond to threats by communicating with other

cybersecurity tools and assets. This may be vital when it comes to reacting appropriately using the tools in your cybersecurity stack.

- Check whether the credentials for remote access to your network have been potentially compromised. Check Event Collector error codes and look for unknown accounts in your Active Directory. Also, enable Multi-factor authentication in your network.
- If you identify a network scan incident in the same network segment and/or label where other IOCs have been detected, and the network scan incident wasn't caused by the work of your security team, review the detected IOCs and whether they are currently blocked by your Firewall or other components of your security infrastructure.
- Create and apply access control lists on your firewalls and routers. Remember, In a [Zero Trust model](#), there is no such thing as a trusted source. As such, every request to access the system must be authenticated, authorized, and encrypted.
- Isolate the targeted device from your network. Verify that security updates on the device are up to date, as well as the Access Control Lists on services. Also, review your access logs and force Multi-factor authentication.

Post-Incident Activity

This last phase is designed to incorporate the lessons learned about the incident and be better prepared in the future.

How Lumu Helps

Continuously monitor that the compromise has been eradicated and refine current defense and response infrastructure for the future.

Recommended Actions

- Use Lumu to detect the devices in your network that performed the network scans and make sure that no additional incidents of this type are reported. In addition, you can also conduct awareness campaigns focusing on the users that own and/or manage those devices.
- To determine whether or not a device is at risk, you'll need to find out what an attacker would see if they perform a port scan on said device. One way to do this is to use a tool like [Nmap](#), a free port scanner which, unfortunately, is used by hackers to carry out attacks but isn't inherently dangerous to use on your own device. From there, you can see which of the device's ports show as "open."

ID	Mitigation	Description
M1042	Disable or Remove Feature or Program	Ensure that unnecessary ports and services are closed to prevent risk of discovery and potential exploitation.

M1031	Network Intrusion Prevention	Use network intrusion detection/prevention systems to detect and prevent remote service scans.
M1030	Network Segmentation	Ensure proper network segmentation is followed to protect critical servers and devices.

- Validate whether the contacted IOCs on detected endpoints are not being seen in other devices, as this may indicate that further network scans can be performed.
- Conduct root cause analysis. You can use context information from the Lumu Portal for more details.
- Consider Zero Trust architecture in order to micro-segment your network to reduce the potential attack surface.
- Identify details of the cybersecurity incident, including timing, type, and location. The incident and its effects need to be remediated across the entire network.
- Consider implementing and deploying deception technologies to attract cyber criminals away from your organization's true assets. These decoys mimic legitimate servers, applications, and data so that the criminal is tricked into believing that they have infiltrated and gained access to your organization's most important assets [when in reality they have not](#).
- Hackers usually probe networks for vulnerabilities using port scan attacks; however, it is possible to set up your organization's network to use this against them and slow attackers down. By using firewalls to redirect open ports to “honeypots” or empty hosts, you can turn a port scan that would take hackers just a few seconds into a [7-hour job](#). Capitalizing on the frequency of port scans by using deception defenses that bait and trap hackers can be an effective technique that requires relatively little investment.